secureverse

Current Risk Summary report

Sun Mar 08 2026 18:08:02 GMT+0000 (Coordinated Universal Time)

Project description: *No description*

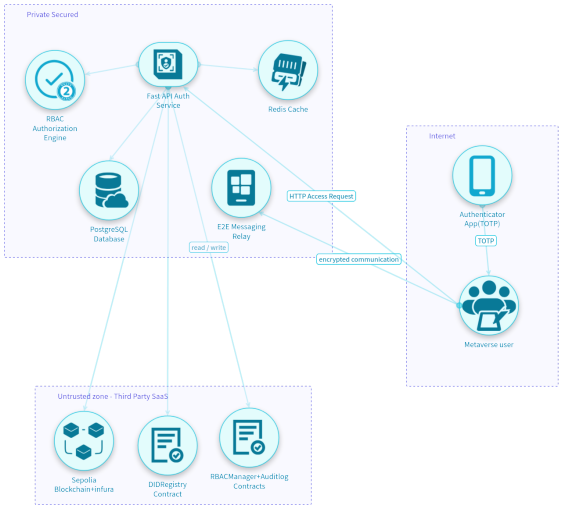
Filtered by: *No filters*

Unique ID: secureverse-1772967171562

Owner: Isra Chaudry

Workflow state: Final Version

Tags: *No tags*



Content menu

Current risk summary

Components

Accepted Risks

Current Risks

- Authenticator App(TOTP)
- DIDRegistry Contract
- E2E Messaging Relay
- Fast API Auth Service
- Metaverse user
- PostgreSQL Database
- RBAC Authorization Engine
- RBACManager+Auditlog Contracts
- Redis Cache
- Sepolia Blockchain+infura

Current Risk summary

Inherent risk description: The Inherent Risk before countermeasures were applied.
- **Risk Rating:** 68.9000015258789% High

The Current Risk description (the risk we are at now): The Current Risk is based on the current implementation status of the countermeasures and test results.
- **Risk Rating:** 35.9599990844726 56% Medium

Projected Risk description: The Projected Risk is the level of risk that would be reached should the required countermeasures be implemented.
- **Risk Rating:** 35.9599990844726 56% Medium

Components

- Authenticator App(TOTP)
- DIDRegistry Contract
- E2E Messaging Relay
- Fast API Auth Service
- Metaverse user
- PostgreSQL Database
- RBAC Authorization Engine
- RBACManager+Auditlog Contracts
- Redis Cache
- Sepolia Blockchain+infura

Accepted Risks

No data

Current Risks

Component: Authenticator App(TOTP)

Use case: Information Disclosure

CRT1. Threat name: Data leakage via insecure backup or synchronization services
- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR1. Countermeasure name:** Implement secure backup and data synchronization protocols
  - **Status:** IMPLEMENTED

CRT2. Threat name: Device theft or loss leading to data compromise
- **Inherent risk:** Critical
- **Current risk:** Critical
- **Projected risk:** Critical
- **State:** Exposed
- **CR2. Countermeasure name:** Enable remote wipe and tracking features
  - **Status:** RECOMMENDED

CRT3. Threat name: Exposure of sensitive data due to insecure local storage
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR3. Countermeasure name:** Implement secure data storage and device encryption
  - **Status:** RECOMMENDED

CRT4. Threat name: Interception of network communications
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR4. Countermeasure name:** Use VPN and enforce encrypted communication channels
  - **Status:** RECOMMENDED

CRT5. Threat name: Malware infections on the mobile device
- **Inherent risk:** Critical
- **Current risk:** Critical
- **Projected risk:** Critical
- **State:** Exposed
- **CR5. Countermeasure name:** Deploy mobile anti-malware solutions
  - **Status:** RECOMMENDED

Use case: Tampering

CRT6. Threat name: Exploitation of unpatched mobile OS vulnerabilities
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR6. Countermeasure name:** Configure automatic mobile OS updates
  - **Status:** RECOMMENDED

CRT7. Threat name: Infiltration of malicious applications
- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR7. Countermeasure name:** Enforce app store whitelisting and robust app vetting
  - **Status:** IMPLEMENTED

Use case: Elevation of Privilege

CRT8. Threat name: Exploitation of vulnerabilities in installed apps
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR8. Countermeasure name:** Enforce regular app updates and conduct vulnerability scanning

- **Status:** RECOMMENDED

Use case: Spoofing

CRT9. Threat name: Phishing attacks targeting mobile users
- **Inherent risk:** Critical
- **Current risk:** Critical
- **Projected risk:** Critical
- **State:** Exposed
- **CR9. Countermeasure name:** Deploy mobile anti-phishing protection
  - **Status:** RECOMMENDED

CRT10. Threat name: Unauthorized access due to weak device authentication
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR10. Countermeasure name:** Implement strong device authentication
  - **Status:** RECOMMENDED

Component: DIDRegistry Contract

Use case: Information Disclosure

CRT11. Threat name: Attackers gain access by stealing user information through common vulnerabilities
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR11. Countermeasure name:** Test and verify Smart Contracts for code correctness
  - **Status:** IMPLEMENTED

Use case: Tampering

CRT12. Threat name: Data is intentionally or accidentally deleted
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR12. Countermeasure name:** Implement robust disaster recovery plans for Smart Contract
  - **Status:** RECOMMENDED

CRT13. Threat name: Exploitation of code vulnerabilities due to complexity
- **Inherent risk:** Critical
- **Current risk:** Critical
- **Projected risk:** Critical
- **State:** Exposed
- **CR13. Countermeasure name:** Reduce code complexity in Smart Contract
  - **Status:** RECOMMENDED

CRT14. Threat name: Manipulation of governance systems
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR14. Countermeasure name:** Design secure governance systems for Smart Contract
  - **Status:** RECOMMENDED

Use case: Elevation of Privilege

CRT15. Threat name: Privilege abuse
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR15. Countermeasure name:** Design proper access controls for Smart Contract
  - **Status:** RECOMMENDED

CRT16. Threat name: Unauthorized execution
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated

- **CR16. Countermeasure name:** Use require(), assert(), and revert() statements for contract safety in Smart Contract
  - **Status:** IMPLEMENTED

Component: E2E Messaging Relay

Use case: Spoofing

CRT17. Threat name: Attackers attempt to access sensitive information
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR17. Countermeasure name:** Implement two-factor authentication to provide an extra layer of security
  - **Status:** IMPLEMENTED
- **CR18. Countermeasure name:** Implement encryption of communications
  - **Status:** IMPLEMENTED
- **CR19. Countermeasure name:** Use secure storage mechanisms
  - **Status:** IMPLEMENTED

Use case: Elevation of Privilege

CRT18. Threat name: Attackers exploit vulnerable dependencies to execute malicious activities
- **Inherent risk:** Medium
- **Current risk:** Medium
- **Projected risk:** Medium
- **State:** Exposed
- **CR20. Countermeasure name:** Use the app sandbox feature provided by the operating system to contain the app and limit its access
  - **Status:** RECOMMENDED

CRT19. Threat name: Attackers gain unauthorized access to the app's functions or data
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR21. Countermeasure name:** Validate all user inputs to protect against injection attacks
  - **Status:** IMPLEMENTED

Component: Fast API Auth Service

Use case: Elevation of Privilege

CRT20. Threat name: Attackers gain unauthorized access or elevated privileges, e.g., via stolen credentials, cookies, or tokens
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR22. Countermeasure name:** Use secure access control mechanisms
  - **Status:** IMPLEMENTED

Use case: Tampering

CRT21. Threat name: Attackers inject malicious content, e.g., SQL queries, to manipulate or access data
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR23. Countermeasure name:** Input validation and sanitization
  - **Status:** IMPLEMENTED

Use case: Information Disclosure

CRT22. Threat name: Attackers intercept or eavesdrop on sensitive information during transmission
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR24. Countermeasure name:** Enforce secure configuration and encryption
  - **Status:** RECOMMENDED

Use case: Denial of Service

CRT23. Threat name: Attackers use enumeration to discover valid user identifiers, potentially creating a Denial of Service (DoS) condition

- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR25. Countermeasure name:** Rate limiting and proper resource management
  - **Status:** RECOMMENDED

Use case: Repudiation

CRT24. Threat name: Lack of evidences of misuse due to insufficient logging

- **Inherent risk:** Medium
- **Current risk:** Medium
- **Projected risk:** Medium
- **State:** Exposed
- **CR26. Countermeasure name:** Create a policy and workflow for comprehensive logging and monitoring
  - **Status:** RECOMMENDED

Component: Metaverse user

Use case: Tampering

CRT25. Threat name: An adversary may input adversarial examples to the deployed model

- **Inherent risk:** Critical
- **Current risk:** High
- **Projected risk:** High
- **State:** Partly-Mitigated
- **CR27. Countermeasure name:** Control users' access to models
  - **Status:** RECOMMENDED
- **CR28. Countermeasure name:** Consider defenses against adversarial tampering such as adversarial training methods or data preprocessing-based approaches
  - **Status:** IMPLEMENTED
- **CR29. Countermeasure name:** Perform input validation, e.g., via anomaly detection
  - **Status:** RECOMMENDED

CRT26. Threat name: An adversary may tamper with the user's input or take control of the input stream/pipeline

- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR30. Countermeasure name:** Protect the user's data and interaction, and data streams used in prediction
  - **Status:** IMPLEMENTED

Component: PostgreSQL Database

Use case: Information Disclosure

CRT27. Threat name: Attackers gain unauthorized access to backups

- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR31. Countermeasure name:** Secure backups
  - **Status:** IMPLEMENTED

CRT28. Threat name: Attackers gain unauthorized access via weak or misconfigured access control

- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR32. Countermeasure name:** Secure setup and access control
  - **Status:** IMPLEMENTED

Use case: Tampering

CRT29. Threat name: Attackers inject malicious code

- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR33. Countermeasure name:** Sanitize and validate user input
  - **Status:** IMPLEMENTED

Use case: Denial of Service

CRT30. Threat name: Database is unavailable, e.g., downtime
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR34. Countermeasure name:** Design for redundancy
  - **Status:** IMPLEMENTED

Component: RBAC Authorization Engine

Use case: Repudiation

CRT31. Threat name: Attackers bypass detection due to lack of logging and monitoring
- **Inherent risk:** Medium
- **Current risk:** Medium
- **Projected risk:** Medium
- **State:** Exposed
- **CR35. Countermeasure name:** Log key actions and monitor for unusual activity
  - **Status:** RECOMMENDED

Use case: Tampering

CRT32. Threat name: Attackers exploit insufficient token validation
- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR36. Countermeasure name:** Validate tokens by verifying signature, claims, and expiration
  - **Status:** IMPLEMENTED

Use case: Information Disclosure

CRT33. Threat name: Attackers exploit open redirects
- **Inherent risk:** Medium
- **Current risk:** Medium
- **Projected risk:** Medium
- **State:** Exposed
- **CR37. Countermeasure name:** Validate redirect URIs against a strict whitelist
  - **Status:** RECOMMENDED

CRT34. Threat name: Attackers intercept tokens over unencrypted communication channels
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR38. Countermeasure name:** Enforce HTTPS and modern TLS for secure communication
  - **Status:** RECOMMENDED

Use case: Elevation of Privilege

CRT35. Threat name: Attackers exploit weak access policies
- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR39. Countermeasure name:** Enforce principle of least privilege in scope management
  - **Status:** IMPLEMENTED

Use case: Spoofing

CRT36. Threat name: Attackers inject malicious authorization codes
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR40. Countermeasure name:** Bind authorization codes to specific clients and enforce PKCE for public clients
  - **Status:** IMPLEMENTED

CRT37. Threat name: Attackers perform brute force on client credentials

- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR41. Countermeasure name:** Mandate high-entropy client secrets and protect against brute-force attacks
  - **Status:** IMPLEMENTED

CRT38. Threat name: Attackers perform token replay attacks
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR42. Countermeasure name:** Use short-lived access tokens with refresh token rotation and validate token binding
  - **Status:** RECOMMENDED

Component: RBACManager+Auditlog Contracts

Use case: Information Disclosure

CRT39. Threat name: Attackers gain access by stealing user information through common vulnerabilities
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR43. Countermeasure name:** Test and verify Smart Contracts for code correctness
  - **Status:** RECOMMENDED

Use case: Tampering

CRT40. Threat name: Data is intentionally or accidentally deleted
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR44. Countermeasure name:** Implement robust disaster recovery plans for Smart Contract
  - **Status:** RECOMMENDED

CRT41. Threat name: Exploitation of code vulnerabilities due to complexity
- **Inherent risk:** Critical
- **Current risk:** Critical
- **Projected risk:** Critical
- **State:** Exposed
- **CR45. Countermeasure name:** Reduce code complexity in Smart Contract
  - **Status:** RECOMMENDED

CRT42. Threat name: Manipulation of governance systems
- **Inherent risk:** High
- **Current risk:** High
- **Projected risk:** High
- **State:** Exposed
- **CR46. Countermeasure name:** Design secure governance systems for Smart Contract
  - **Status:** RECOMMENDED

Use case: Elevation of Privilege

CRT43. Threat name: Privilege abuse
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR47. Countermeasure name:** Design proper access controls for Smart Contract
  - **Status:** IMPLEMENTED

CRT44. Threat name: Unauthorized execution
- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR48. Countermeasure name:** Use require(), assert(), and revert() statements for contract safety in Smart Contract
  - **Status:** IMPLEMENTED

Component: Redis Cache

Use case: Denial of Service

CRT45. Threat name: Cache exhaustion due to excessive data caching
- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR49. Countermeasure name:** Cache allocation and resource management
  - **Status:** IMPLEMENTED

CRT46. Threat name: Denial-of-service attacks targeting cache memory
- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR50. Countermeasure name:** Cache resource management and monitoring
  - **Status:** IMPLEMENTED

Use case: Tampering

CRT47. Threat name: Cache poisoning through malicious software
- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR51. Countermeasure name:** Cache poisoning detection and prevention
  - **Status:** IMPLEMENTED

Use case: Information Disclosure

CRT48. Threat name: Exploiting cache side-channel vulnerabilities to leak sensitive data
- **Inherent risk:** Critical
- **Current risk:** Critical
- **Projected risk:** Critical
- **State:** Exposed
- **CR52. Countermeasure name:** Cache isolation and mitigation for side-channel attacks
  - **Status:** RECOMMENDED

CRT49. Threat name: Exploiting cache timing attacks to infer sensitive data
- **Inherent risk:** Critical
- **Current risk:** Critical
- **Projected risk:** Critical
- **State:** Exposed
- **CR53. Countermeasure name:** Mitigation of cache timing attacks
  - **Status:** RECOMMENDED

Component: Sepolia Blockchain+infura

Use case: Information Disclosure

CRT50. Threat name: An attacker examines a target system to find sensitive data that has been embedded within it
- **Inherent risk:** Medium
- **Current risk:** Medium
- **Projected risk:** Medium
- **State:** Exposed
- **CR54. Countermeasure name:** Implement effective endpoint security in Blockchain Network
  - **Status:** RECOMMENDED

End of Current Risk Report